



腾讯安全



云鼎实验室

锋刃无影 御见未来

腾讯安全沙龙第4期（长沙站）



关于我

About me

马良 格物实验室(IOT/工控/无人机/车联网/卫星/芯片) 安全研究员

具有十多年嵌入式软硬件开发经验, 擅长智能设备的固件提取和安全研究

2016 Xpwn比赛 “西门子PLC蠕虫” 演示

2018 看雪开发者大会演讲 “智能设备固件提取的十种方法”

2018 JD-HITB会议演讲嘉宾 《Vocore2在安全研究的应用》

2018 GeekPwn<机器特工>机器人设计和制作

2021 GeekPwn<电力猫>插线板演示工具制作

2022 看雪开发者大会演讲 “车联网渗透套路”

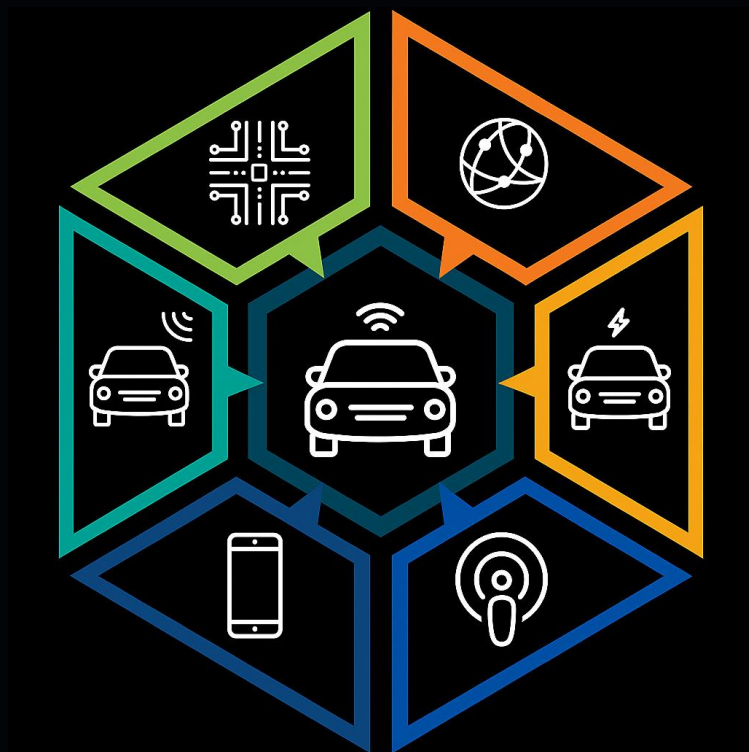
2023 Kcon 《近源攻击的安全研究思路》

2023 雄安 汽车漏洞攻防技术研讨会 《网联汽车漏洞挖掘思路》

车联网漏洞挖掘方法及典型案例剖析



目录



- 车联网安全现状
- 车联网攻击技术
- 车联网安全比赛经验
- 大型车联网安全事件
- 车联网安全解决方案

车联网安全现状-技术变革致信息安全形势严峻

汽车发展阶段

L0-L1: 传统/辅助驾驶
完成人类驾驶 / 辅助驾驶

L2-L4: 互联/自动驾驶
部分/有条件/高度自动驾驶
(核心变革阶段)

L5: 完全自动驾驶
未来最终形态

互联汽车

复杂的移动计算平台

三大发展趋势

智能化

网联化

更多接入连接

安全威胁分析

Key Fob Hacking (车钥匙破解)

Personal Data (个人数据泄露)

OBD-II Hacking (车载诊断系统)

V2I (车路通信攻击)

V2V (车车通信攻击)

Malware - Exploits (恶意软件)

Spam - Advertising (垃圾信息)

关键统计数据

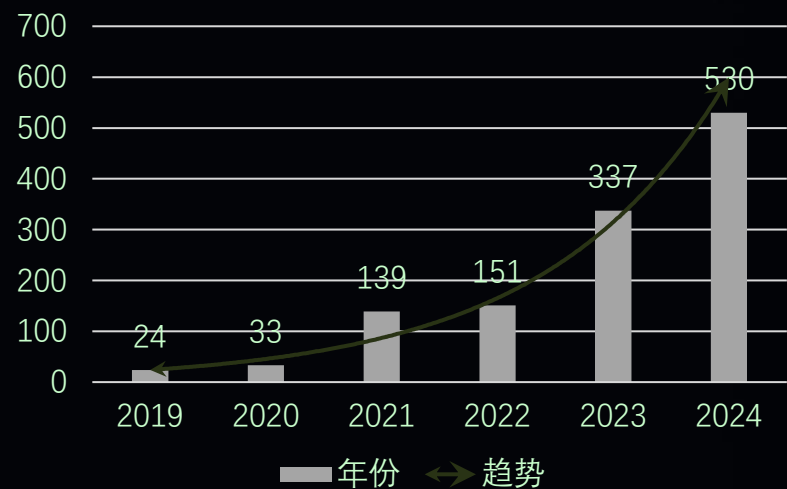
- 最新汽车搭载超 **100** 个ECU单元
- 运行代码量超 **6000万** 行
- 无人驾驶汽车代码量达 **1亿** 行以上
- CNNVD漏洞数量年增长 **20%** 以上

核心矛盾与挑战

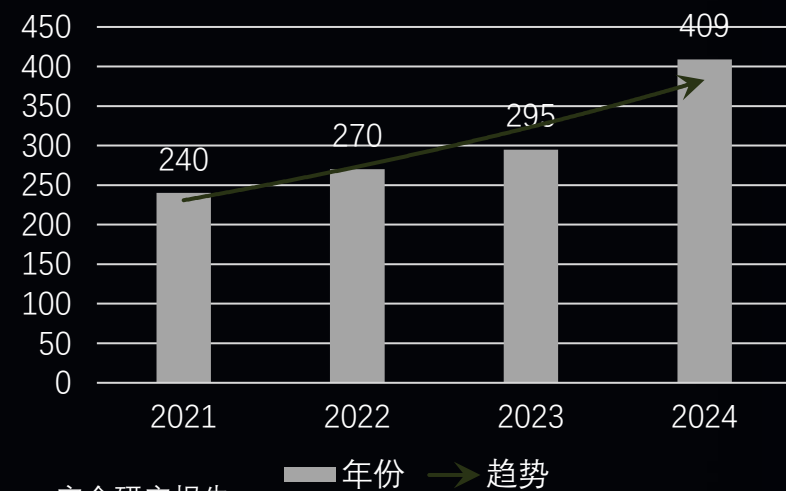
汽车的 **智能化** 和 **网联化** 程度越高，其面临的 **网络安全风险** 就越大。汽车安全必须从传统物理安全扩展到网络安全领域，这对制造商、监管和用户均提出了新的挑战，亟需建立完善的网络安全防护体系。

车联网安全现状 - 风险增加&新形势

汽车CVE增长



汽车网络安全事件

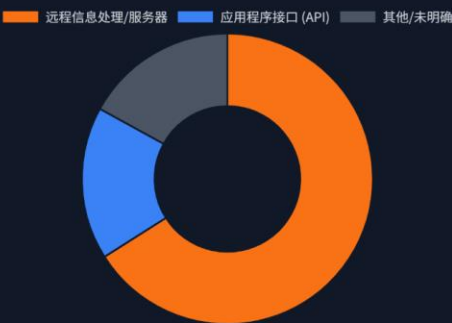


数据来源：Upstream安全研究报告

攻击源头：后端基础设施成为主要目标

攻击者的焦点已明显从车辆本身转移至其背后的云和服务器基础设施。通过攻击这些集中化的系统，他们能够以更低成本实现更大范围的影响。远程攻击已成为常态。

主要攻击途径分布 (2024)



高达66%的攻击直接指向远程信息处理和应用服务器，API相关攻击也占据了17%的份额，后端安全防护刻不容缓。

远程攻击的主导地位



92%的攻击为远程发起，其中绝大多数（85%）为远距离攻击，意味着攻击者无需物理接近车辆即可发动攻击，这极大扩展了威胁范围。

攻击剖析：三大核心威胁

攻击者的动机多样，但主要集中在经济利益和系统控制上。数据泄露、勒索软件和车辆功能操纵成为2024年最普遍、最具破坏性的攻击后果，直接威胁到用户隐私、财产乃至人身安全。

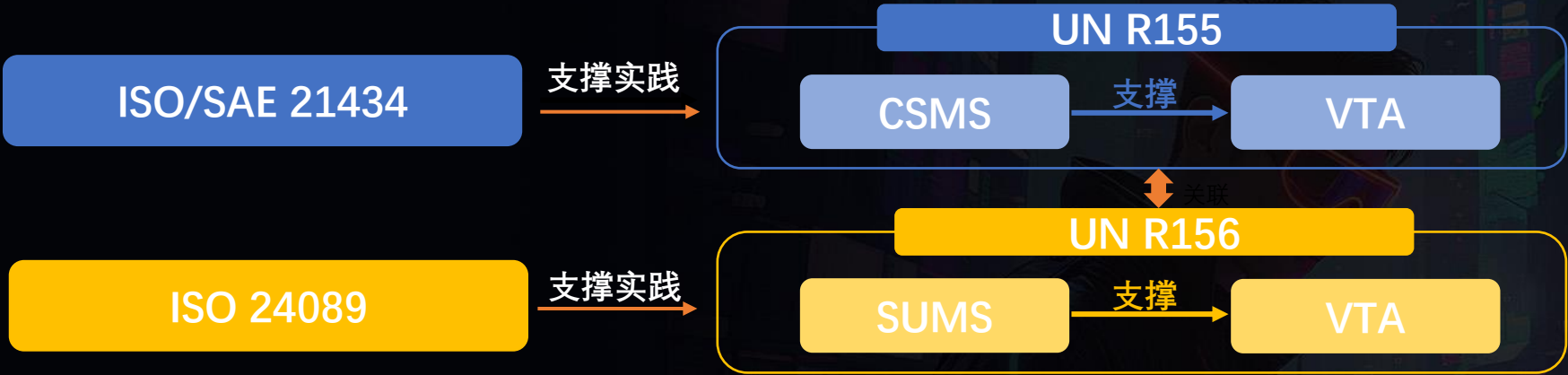
2024年事件影响类型分布



数据和隐私泄露事件占比高达60%，而超过三分之一的事件涉及对车辆系统的直接操纵，凸显了安全与功能安全融合的紧迫性。

车联网安全现状-网络安全准入比重增加

2020年6月，联合国世界车辆法规协调论坛（简称“WP29”）发布2项智能网联汽车R155、R156法规，即网络安全（Cybersecurity）、软件升级（Software updates），适用于1958协议下成员国（覆盖所有欧盟国家和其他OECD国家），生产汽车若销售至1958成员国则必须通过认证。UN R155法规是全球第一个汽车信息安全强制法规，这意味着车辆的信息安全已经从符合标准进入到遵从法规的时代。



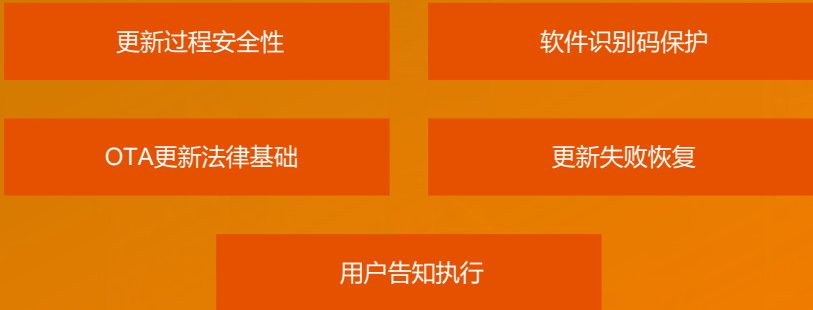
编号	发布日期	内容
DB4403	2024年1月22日	智能网联汽车网络安全技术要求
GB44495-2024	2026年1月1日	汽车整车信息安全技术要求
GB44496-2024	2026年1月1日	汽车软件升级通用技术要求
GB44497-2024	2026年1月1日	智能网联汽车自动驾驶数据记录系统

车联网安全现状-技术变革致信息安全形势严峻

UN R155 网络安全管理体系(CSMS)



UN R156 软件更新管理体系(SUMS)



车辆全生命周期覆盖



强制实施时间线



车联网网络安全十大挑战 (来源:中汽数据 2024.11.22)



数据来源: Upstream
安全研究报告

两届Pwn2own Automotive漏洞概述



Pwn2own Automotive 2024 概述

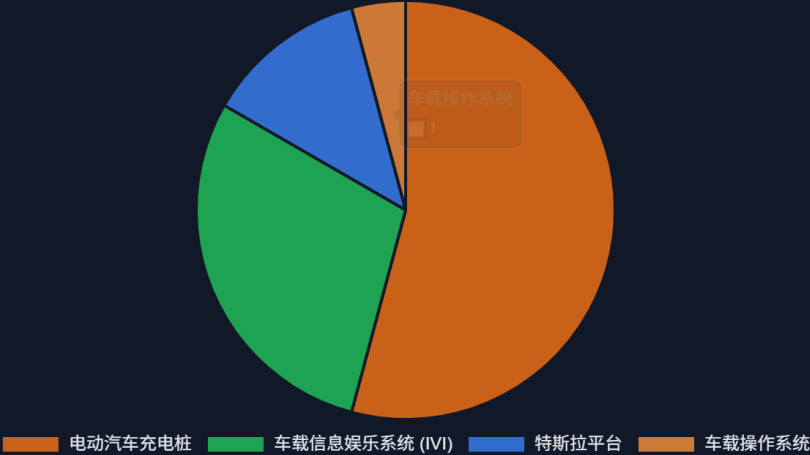
漏洞类型分布：传统缺陷在汽车领域重现

分析发现，大量漏洞是IT领域的“老问题”，如内存安全和注入缺陷，表明汽车行业在基础安全实践方面存在巨大改进空间。



主要攻击类别分布

电动汽车充电桩和车载信息娱乐 (IVI) 系统成为攻击的重灾区，暴露了这些关键基础设施和用户交互界面的脆弱性。



攻击剖析：多漏洞利用链的力量

顶尖攻击者很少依赖单个漏洞。他们通过巧妙地将多个看似独立的低危缺陷串联起来，构建复杂的“攻击链”，最终实现完全的系统控制。这展示了纵深防御的重要性。

案例研究：Pioneer IVI系统远程代码执行



被攻破的充电桩品牌

多个知名品牌的充电桩被成功攻破，凸显了充电设施作为潜在攻击跳板的巨大风险，可能影响车辆甚至电网安全。



阿尔派Halo9 IVI(Pwn2own 2024)发现的四个漏洞

ZDI-24-846 (CVE-2024-23924): 这是本次事件的核心漏洞。它存在于UPDM_wemCmdCreatSHA256Hash函数中，是一个命令注入漏洞。由于系统未能正确验证用户通过USB设备提供的字符串，攻击者可以构造恶意输入，最终在root权限下执行任意代码。该漏洞的CVSS评分为6.8，攻击向量为物理接触（AV:P）。

ZDI-24-849 (CVE-2024-23961): 由NCC Group发现的另一个命令注入漏洞，位于UPDM_wemCmdUpdFSpeDecomp函数中。同样通过物理接触（USB）触发，并能获得root权限。研究人员通过这个漏洞成功在IVI屏幕上运行经典游戏《毁灭战士》（Doom），展示其危害性。

ZDI-24-844 (CVE-2024-23923): 这是一个释放后重用（Use-After-Free）漏洞，存在于prh_l2_sar_data_ind函数中。攻击者可在邻近网络（AV:A）中利用此漏洞，无需认证即可执行代码，CVSS评分高达8.8。

ZDI-24-848 (CVE-2024-23935): 这是一个基于栈的缓冲区溢出漏洞，位于蓝牙协议栈的DecodeUTF7函数中。攻击者通过配对恶意的蓝牙设备即可触发，CVSS评分为8.0。

阿尔派Halo9 IVI系统性安全问题

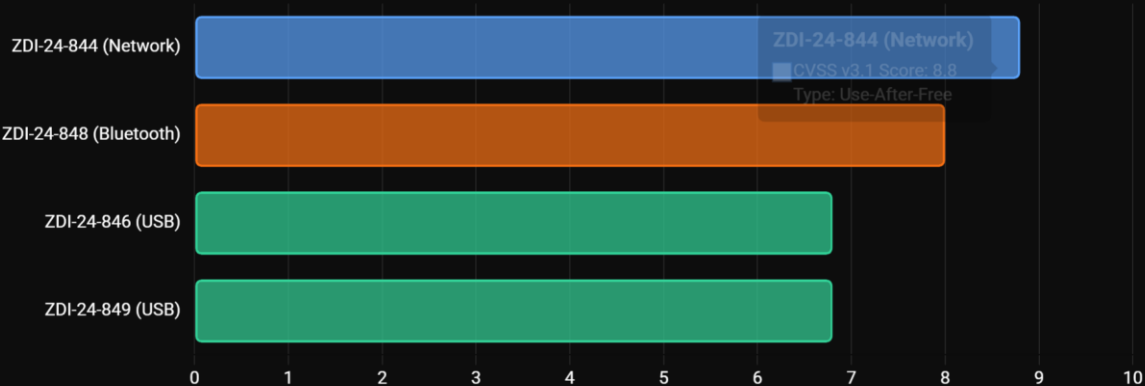
原罪：未加密的固件

一个根本性的设计缺陷为后续所有攻击铺平了道路。研究人员发现eMMC闪存中的固件为未加密的明文，这使得攻击分析从困难的“黑盒测试”转变为一目了然的“白盒分析”。



漏洞严重性评估

发现的多个零日漏洞覆盖了物理、邻近网络和蓝牙等多个维度，CVSS评分最高达 **8.8**，显示出系统缺乏纵深防御。



攻击向量与影响

攻击者可通过多种途径利用漏洞，从物理接触的U盘到临近的恶意设备，最终均可能获得设备的最高控制权（root权限）。

6.8

命令注入
ZDI-24-846 (USB)

6.8

命令注入
ZDI-24-849 (USB)

8.8

释放后重用
ZDI-24-844 (Network)

8.0

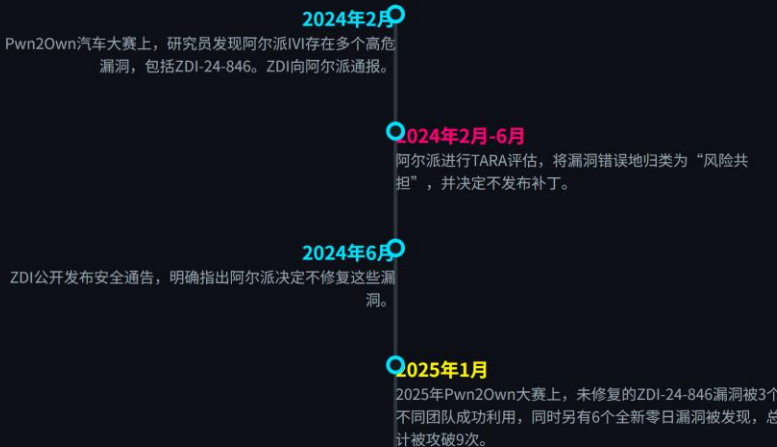
缓冲区溢出
ZDI-24-848 (Bluetooth)

雪上加霜的失误

在白盒分析下，一系列基础性安全疏忽暴露无遗，如同虚设的防线。

- 绕过签名验证的调试后门
- 硬编码在二进制文件中的AES密钥
- 极度脆弱的解压密码: "0123456789"

事件发展时间线



2025年的雪崩

阿尔派的决策直接导致了灾难性后果。旧漏洞被反复利用。更可怕的是，吸引了更多攻击者，并发现了大量全新的零日漏洞。

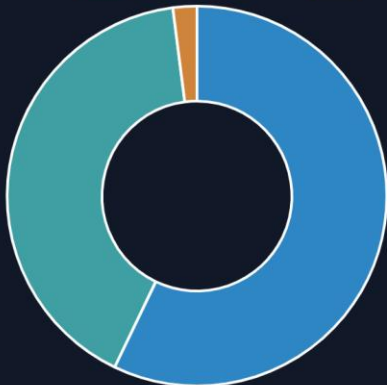
3x 旧漏洞 (ZDI-24-846) 被 **3个独立团队** 重复利用。

6x 全新的、此前未知的 **6个零日漏洞** 被发现并利用。

Pwn2own Automotive 2025 概述

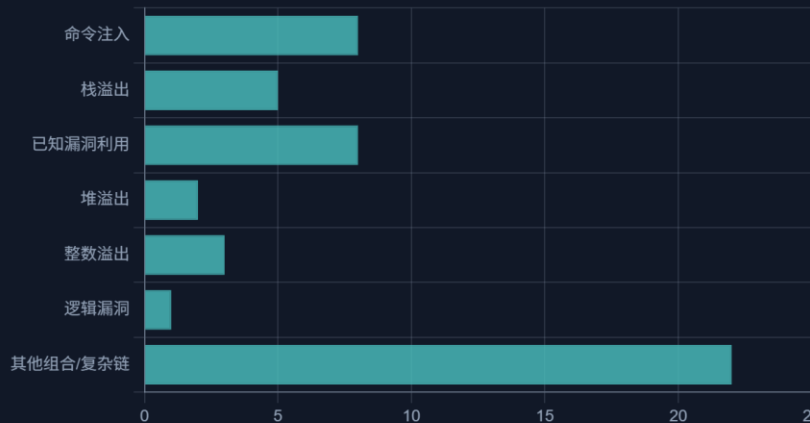
主要攻击目标分布

电动汽车充电桩 车载信息娱乐 (IVI) 车载操作系统 (OS)



被攻破的系统集中车载信息娱乐系统和电动汽车充电桩两大关键领域
这是当前汽车生态系统中最脆弱的两个环节。

常见漏洞类型统计



命令注入和缓冲区溢出等基础性漏洞的持续存在，说明汽车行业在安全编码实践方面仍面临挑战。

焦点厂商案例研究

阿尔派 (Alpine) IVI: 未修复漏洞的警示

一个关于风险接受策略与现实安全冲突的鲜明案例。

1. 发现漏洞
Pwn2Own 2024
ZDI-24-846



2. 厂商决策
援引ISO 21434
“风险共担”



3. 结果
漏洞未修复



4. 再利用
Pwn2Own 2025
多个团队成功

阿尔派决定不修补一个已公开披露的漏洞，而该漏洞随后被多个团队再次利用。
这一事件揭示了合规性解释与实际网络安全防护之间可能存在的巨大鸿沟，为行业敲响了警钟。

特斯拉 (Tesla) 充电桩

特斯拉的Wall Connector成为多个团队的攻击目标，暴露出数值范围检查、逻辑漏洞等多方面的问题。特别是通过充电接口发起的攻击，说明攻击向量正变得复杂和具有物理交互性。

索尼 (Sony) IVI

索尼的IVI系统被发现存在多种漏洞，包括整数溢出、堆溢出，用复杂的利用链实现“零点击”攻击，无需用户交互即可触发，具有高度隐蔽性和潜在危害性，其架构存在多个薄弱环节。

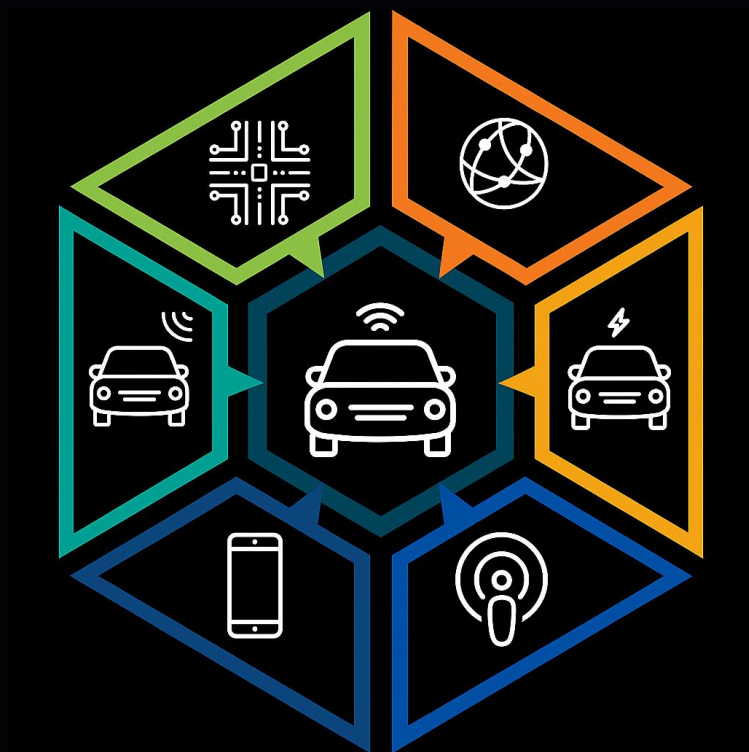
建伍 (Kenwood) IVI

建伍的IVI系统被多个不同团队利用操作系统命令注入漏洞成功攻破。攻击者成功在屏幕上播放了经典游戏的视频。

Ubiquiti 充电桩

研究员利用一个基础性的安全缺陷——硬编码加密密钥——成功攻破系统，并在设备上播放了Rick Astley的视频（即“Rickrolling”）。这反映了设备在安全机制设计上存在缺陷。

目录

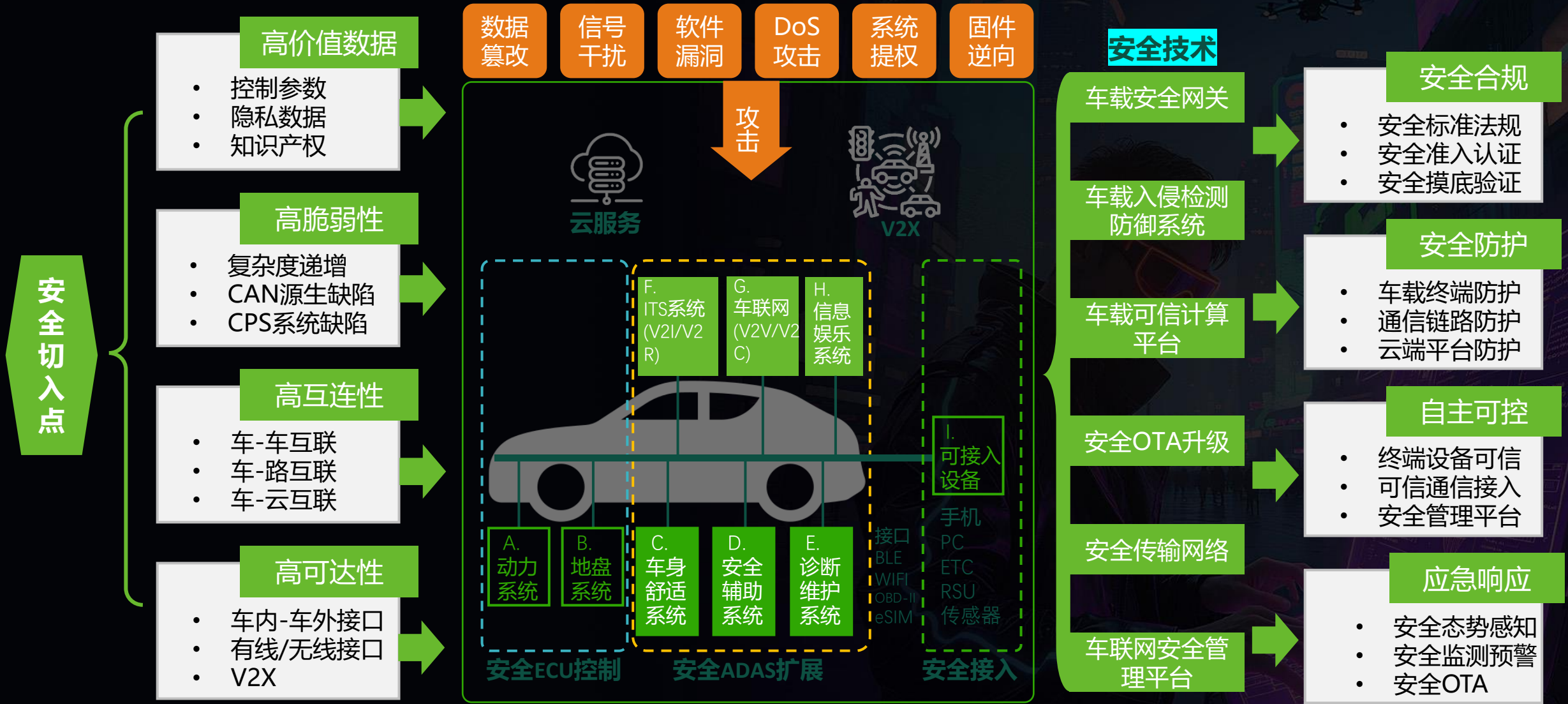


- 车联网安全现状
- 车联网攻击技术
- 车联网安全比赛经验
- 车联网安全解决方案

车联网数据安全威胁架构图



车联网安全技术分析



车联网安全 - 零部件测试

测试方法

弱口令尝试

接入内网

内网扫描

固件分析

弱口令

SSH、WiFi 等存在弱口令、空口令

可执行命令端口暴露

比如设备某端口暴露多个 AT 指令，借助这些指令可以修改设备配置。

敏感信息泄露

某些正在监听的服务，在接收到特制指令后可能返回敏感信息。

风险点

车联网安全 – 常见攻击向量 & 新兴威胁

主要攻击类型



攻击途径统计



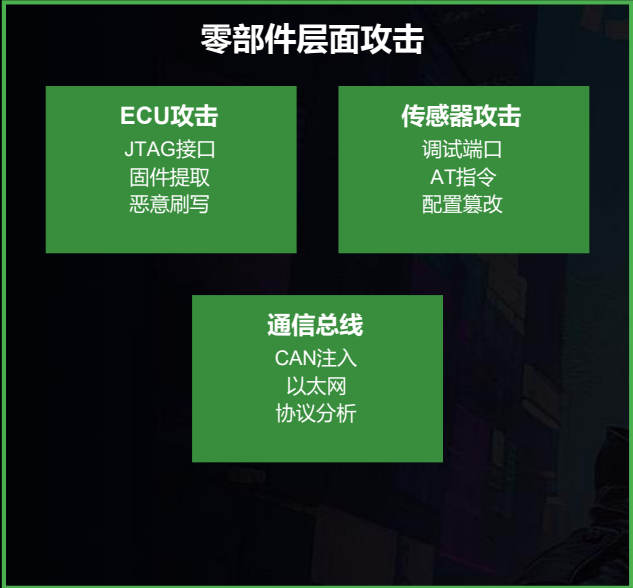
新兴威胁趋势



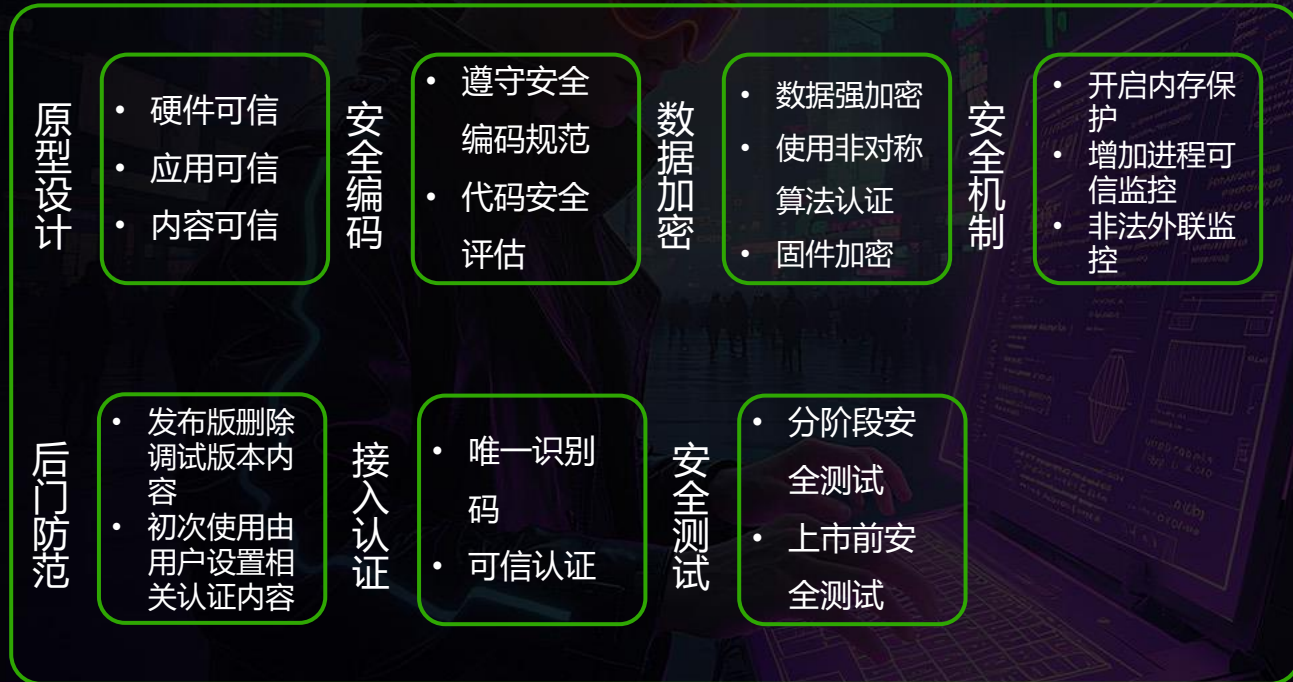
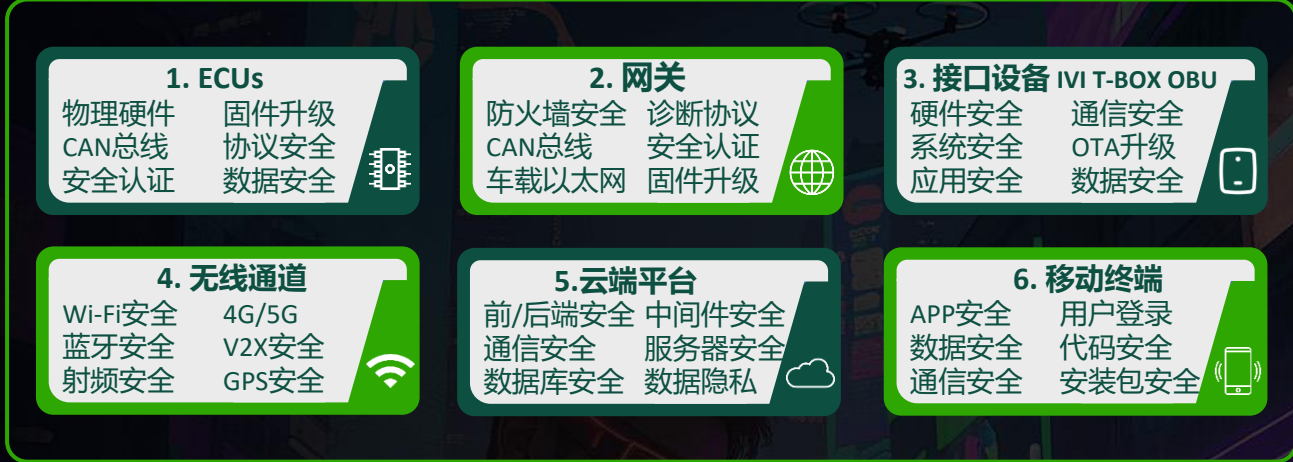
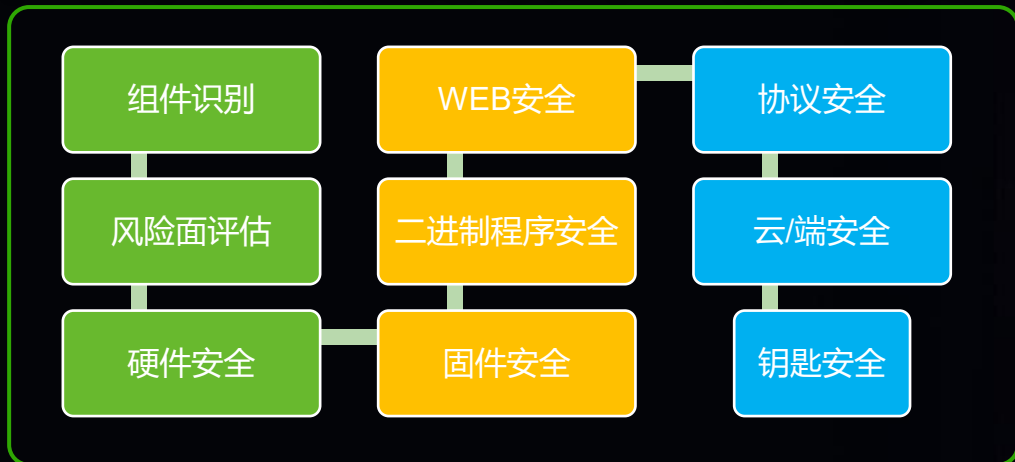
综合防护策略



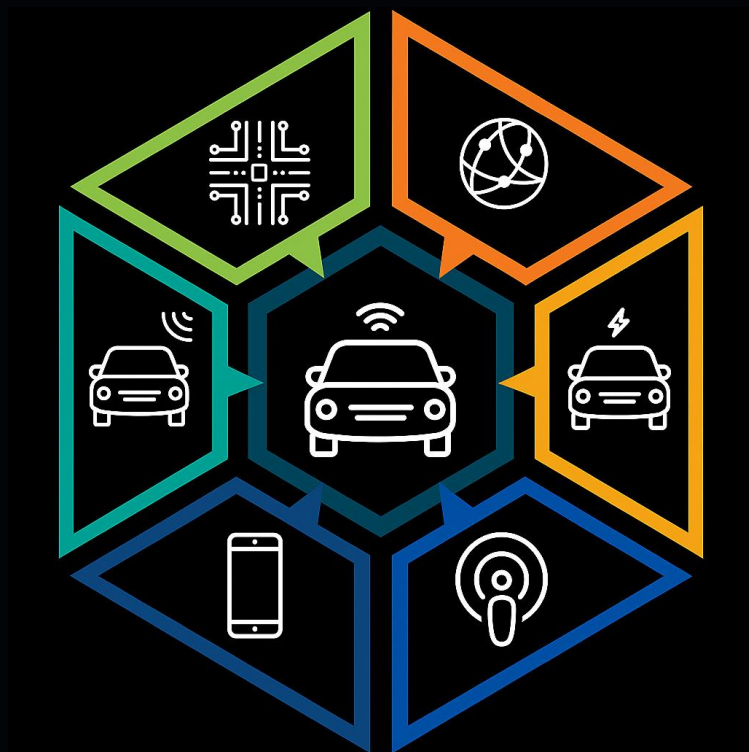
车联网安全 – 典型攻击路径 & 高级攻击技术



车联网安全测试&加固建议



目录



- 车联网安全现状
- 车联网攻击技术
- 车联网安全比赛经验
- 车联网安全解决方案

准备的工具

App & 固件

通用逆向软件 (如: IDA)
MobSF最新 (App逆向)
Frida软件及其易用版本和加强版本
CAN硬件对应的软件
固件逆向分析软件
https抓包 (如: Burpsuite)
各种SDR软件
各种安卓root用的APK
各种安卓adb调试软件
QNX GDB调试软件

存储

TF和SD卡读卡器
U盘 (ext4 / FAT32)
U盘 (带Linux启动功能)
全功能/简易编程器
不同容量的TF卡

线材

双公头USB线
USB安卓数据线
串口线
各种杜邦线
网线 / 飞线 / 焊锡丝
USB键、鼠

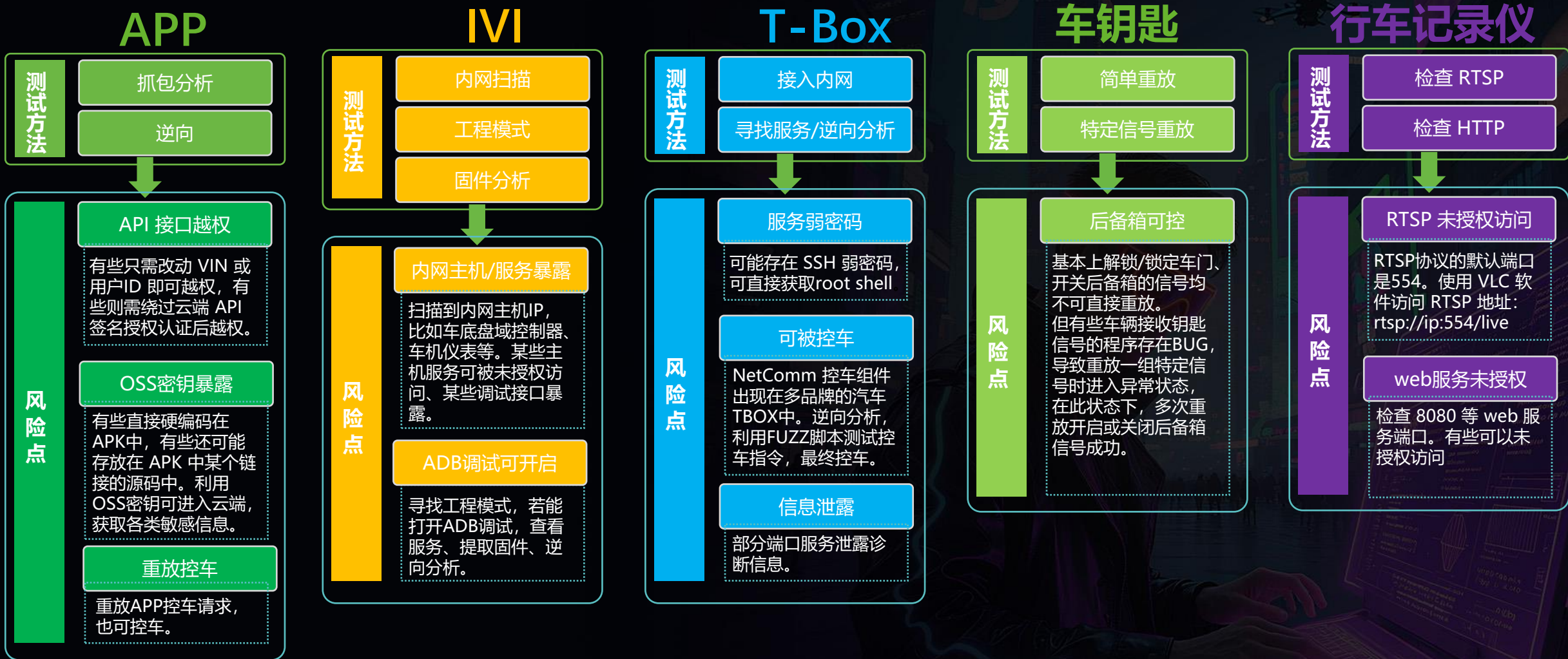
硬件

谷歌手机 (root)
Iphone手机 (越狱)
USB转TTL
万用表
电烙铁和电风枪
车载以太网接入设备
4G上网工具 (可用tcpdump抓包)

无线

无线wi-fi设备
蓝牙抓包设备
PORTAPACK H2 + HACKRF One
SDR设备
4G伪基站劫持
无线鼠标、键盘

车联网整车安全测试技术路线



安全测试重点 – 容易出漏洞的地方



APP测试

- APP脱壳：目前大多数车联网APP都进行加固，可以使用绿盟自研的破盾平台进行脱壳。
- 抓包逆向：签名算法逆向，接口越权，获取车主及车辆敏感信息。
- 密钥泄露：导致云端敏感信息泄露。
- 接口测试：任意车主账户账号接管，任意车辆信息获取。



车辆安全测试

- 固件获取：工程模式开启调试接口获取固件数据，进行逆向工程。
- 密钥查找：分析车机包含的日志/二进制程序，获取密钥，获取云端升级服务权限。
- 车内网络测试：利用IVI作为跳板，对车内的网络进行黑盒扫描测试，并成功获取不同车内节点的root权限。
- 敏感服务测试：对包含行车记录仪在内的组件进行测试，发现暴露的敏感服务，获取行车记录等敏感信息。



无线测试

- SDR重放测试：针对车钥匙使用软件定义无线电设备进行重放攻击，成功对某品牌车辆进行解锁操作。
- 数字钥匙攻击测试：嗅探蓝牙数据包并重放，成功对某品牌车辆进行解锁操作。
- 无钥匙中继测试：车辆端设备对车辆发出的信号进行放大滤波变频，然后通过天线进行发射，车钥匙端设备对此信号进行变频放大滤波，然后发送给车钥匙，即可实现信号的中继。也可以对NFC和BLE信号进行中继。

硬件方面的困难和解决办法

遇到的困难

- 厂商加固了硬件防护
(尤其是工程模式和ADB接口的防护)
- 工程模式增加了进入的权限
(密钥或扫二维码)
- ADB接口启用难度增大
- 安卓系统root权限获取变得困难
- NFC中继攻击方法，硬件还不完善
缺少零件，复现困难
- GPS干扰要求在室外能起作用
才算漏洞

解决办法

- ◀ 通过咸鱼购买到了工程模式密钥
获得ADB权限
- ◀ 在没有root权限的情况下
提取固件，获取到了大部分车机APK包的内容
- ◀ 通过ADB命令
解锁了第三方App的安装
- ◀ NFC中继攻击方法
得到了实战验证的机会
- ◀ fastboot模式获取信息的方法

车机固件测试的困难和突破

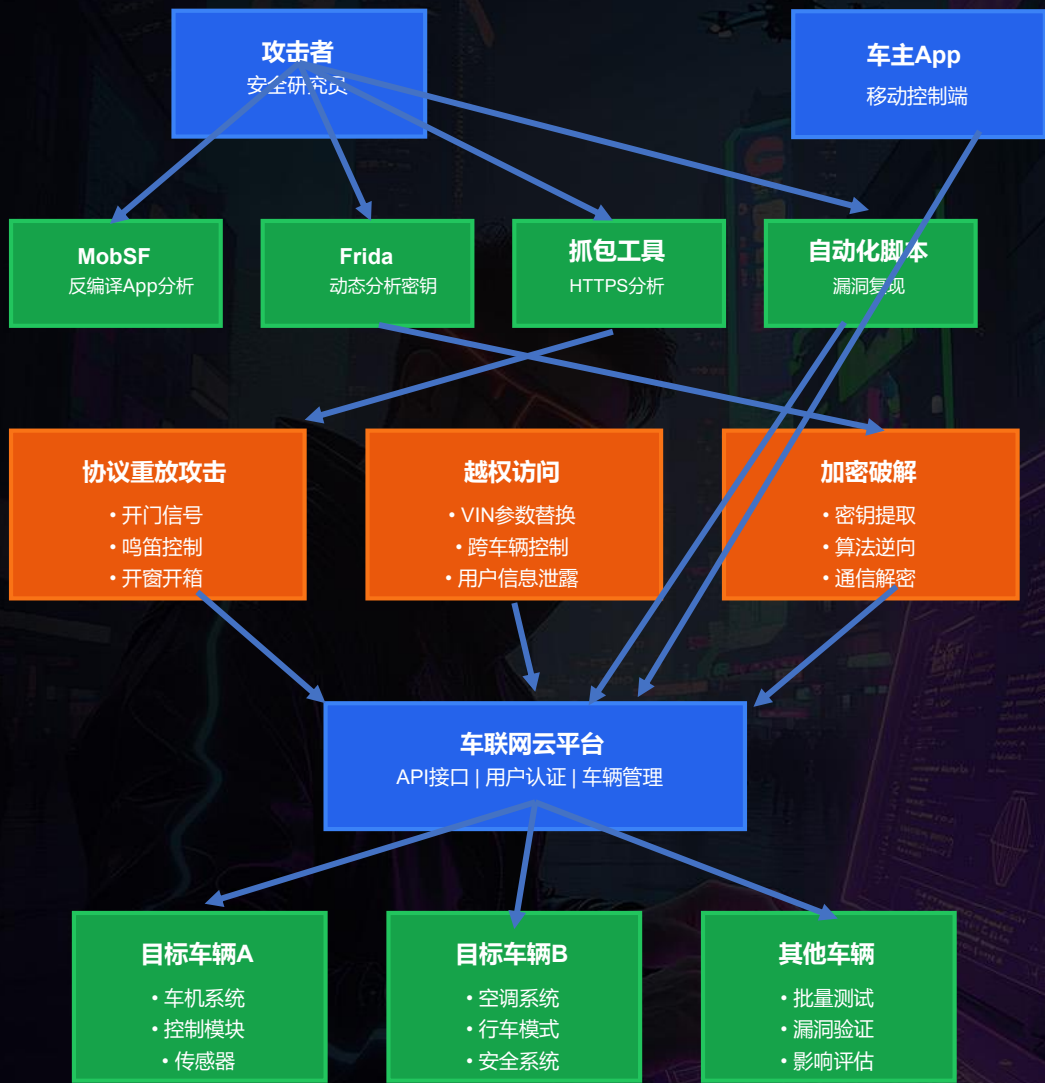
测试困难

- 厂商加固了硬件防护手段
- 隔离车机内的IP网络，扫描不到内部IP
- 权限、命令阉割
- 很多命令获取不到车机内部通信的网段
- 受权限和命令阉割影响，获取不到关键进程ID

解决方案

- 通过各种折腾，发现可疑IP地址
- 发现并验证车机内部IP的ftp权限
- 发现并验证车机内部IP的SSH权限
- 发现安装第三方软件漏洞
- 浏览器XXE信息获取套路的发现和总结

一个常见的控车套路(越权漏洞背后原因和原理)



车联网高危漏洞是怎么被发现的(思路&真实案例)



车联网APP测试流程

加固绕过

密钥查找

流量抓包

签名算法

发现漏洞

加固绕过:

目前安卓上的对抗已经非常成熟，可以去分析IOS平台上的应用，相对难度较小。

针对IOS上的车联网APP，大多数只需要找到越狱检测地方绕过即可。

IOS抓包相对方便，能快速入手。

密钥查找:

分析APP中包含的敏感密钥（FTP密码，OSS密钥）

针对APP内置的URL进行分析，查看是否存在泄露的信息。

流量抓包:

使用frida或者绕过SSL PIN

对于双向HTTPS绑定的，需要找到内置的客户端证书密钥文件，同时找到解密该文件的密码，导入密钥文件到抓包软件中。

签名算法:

抓包出现sign算法，需要分析算法的实现流程，从而达到修改请求的目的。

签名算法会将HTTP请求中的url及参数按照顺序排列并添加一个密钥求出一个哈希值。

发现漏洞:

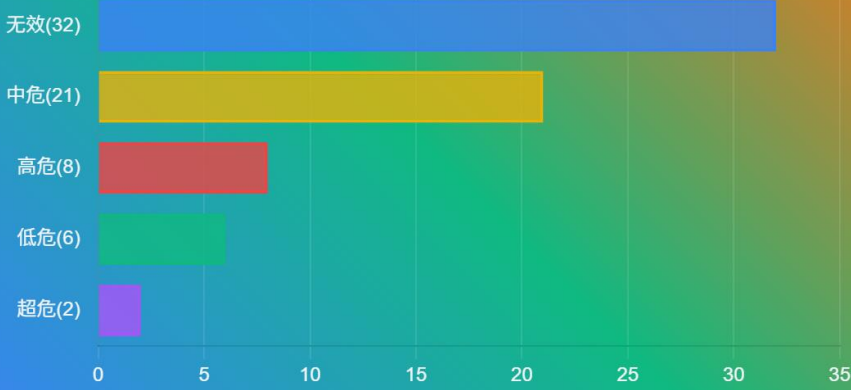
寻找车联网APP社区中的用户信息泄露的漏洞。

寻找越权获取车辆信息的漏洞，VIN可以通过百度搜索出来并进行修改。

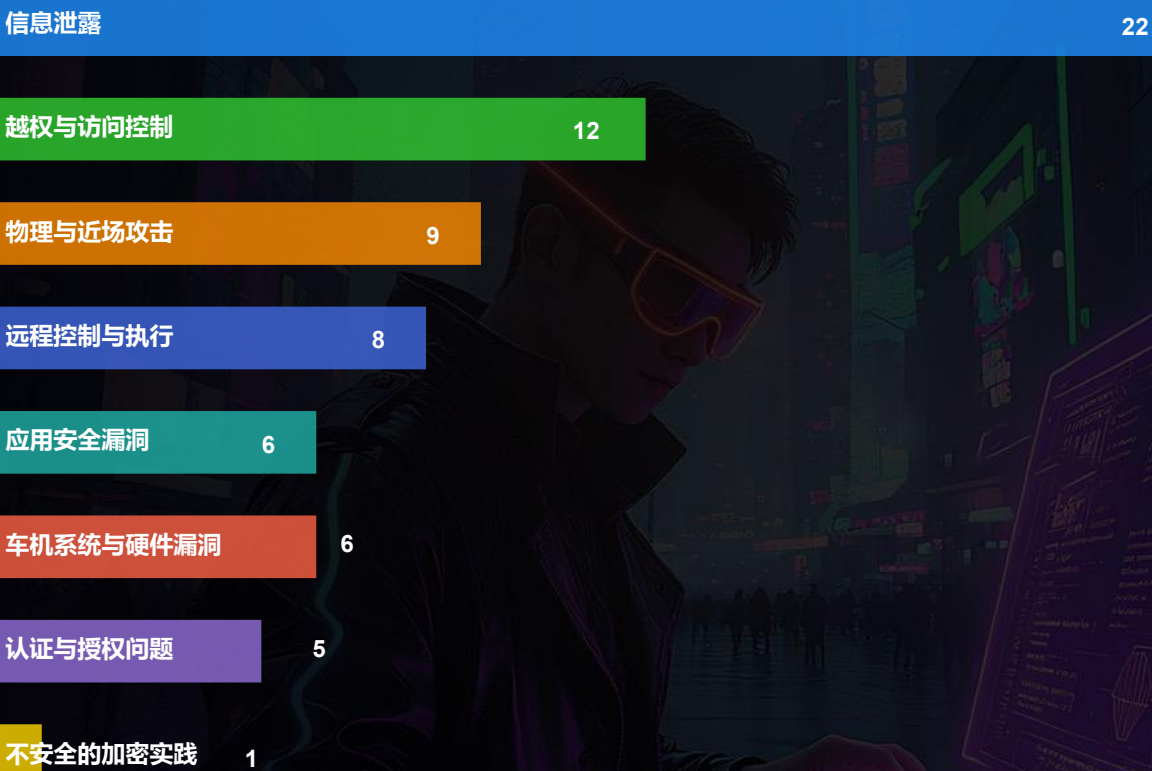
测试APP的登录以及找回密码的流程。

某次比赛发现的漏洞类型的统计

漏洞级别统计



漏洞类型分布



变化&趋势

应用层 (Application Layer)

Android App

- 加固方法增加
- 脱壳更加困难
- 安全防护提升
- PIN码验证增强

iOS App

- 越狱检测增加
- 安全机制完善
- 防护能力增强
- 控车验证严格

厂商安全意识

- 安全意识提升
- 漏洞挖掘难度加大
- 防护策略完善
- 安全投入增加

▶ 难度上升

通信层 (Communication Layer)

App与云端通信

- 签名认证升级为双向认证
- 通信安全性大幅提升
- 中间人攻击防护加强
- 数据传输加密强化

网络协议安全

- 协议层防护增强
- 认证机制完善
- 会话管理优化
- 安全策略更新

▶ 安全增强

硬件层 (Hardware Layer)

ADB接口

- Root权限获取困难
- 调试接口限制增加
- 开发者选项保护
- 系统级权限控制

固件安全

- 固件提取不完整
- 需要巧妙提取方法
- 固件加密保护
- 逆向工程难度提升

车机系统

- App安装权限限制
- 系统封闭性增强
- 第三方应用管控
- 安全沙箱机制

▶ 防护升级

竞赛驱动的漏洞发现与防御策略优化



系统架构说明:



攻击者工具链 - 硬件/软件工具集



攻击目标域 - APP/车载/无线通信



防御策略层 - 应急响应/测试体系/持续博弈

数据流向: 工具 → 攻击 → 防御 → 持续优化的闭环博弈过程

以攻促防的持久价值

威胁挑战

- 0-day漏洞**
Pwn2Own
持续发现
- 勒索攻击**
数据泄露
车企目标
- 软件缺陷**
车辆召回
安全问题
- 供应链**
脆弱性
第三方风险
- 无线攻击**
攻击面
不断扩大
- AI威胁**
充电设施
新兴技术
- 数据安全**
隐私威胁
常态风险

以攻促防核心理念



持续安全运营流程

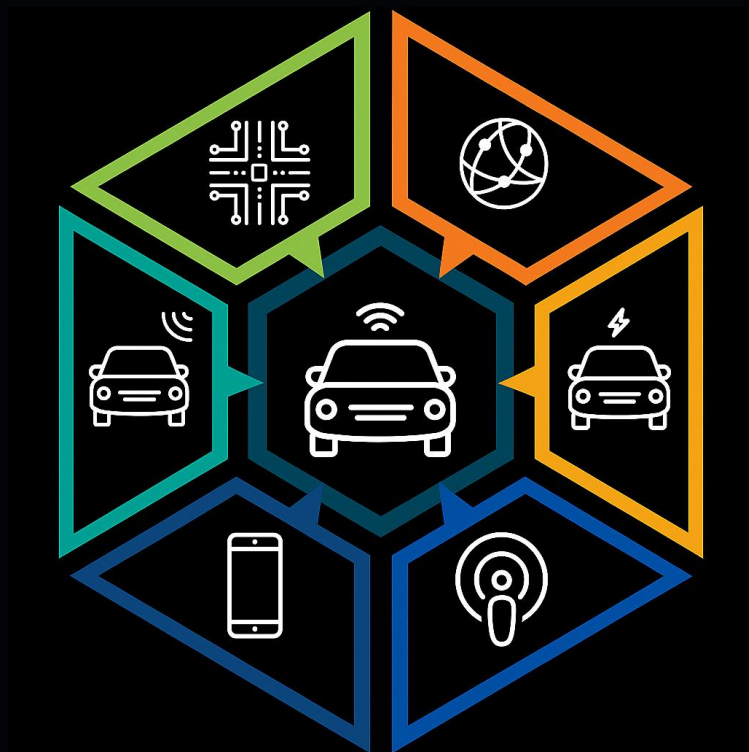
- 设计阶段**
安全需求
威胁建模
架构设计
安全控制
基线设计
- 生产阶段**
安全测试
代码审计
漏洞扫描
渗透测试
安全验证
- 运营阶段**
实时监控
威胁检测
事件响应
安全运营
持续改进
- 维护阶段**
补丁管理
安全更新
配置管理
定期评估
风险评估
- 升级阶段**
技术升级
安全迭代
新威胁应对
防护增强
能力提升
- 报废阶段**
数据销毁
密钥注销
安全清理
合规处置
经验总结
- 持续改进**
经验反馈
流程优化
能力建设
文化培养
创新发展

车联网安全是一个动态持续的过程，唯有将“以攻促防”思维融入全生命周期，才能在网络威胁博弈中占据主动

关键能力建设

- 技术能力**
攻击模拟 | 漏洞挖掘
安全开发 | 测试验证
- 管理能力**
风险评估 | 流程制度
合规管理 | 应急响应
- 运营能力**
监控分析 | 事件处置
威胁狩猎 | 态势感知
- 协同能力**
情报共享 | 联防联控
产业协作 | 标准制定
- 创新能力**
前沿技术 | 新型防护
AI安全 | 智能防御
- 人才能力**
专业培养 | 技能提升
团队建设 | 文化塑造

目录



- 车联网安全现状
- 车联网攻击技术
- 车联网安全比赛经验
- 车联网安全解决方案

车联网安全未来之路：协同共治与持续进化

车联网安全协同共治生态系统

政策制定者与监管机构

法规标准体系

市场监管

产业引导支持

国际合作

零部件供应商 (Tiers)

硬件组件
安全标准

软件组件
安全标准

供应链风险管控
与OEM协作

质量保证体系
持续改进

汽车制造商 (OEMs)

最终责任主体

CSMS
网络安全管理

SUMS
软件更新管理

安全基因

安全厂商

专业化
解决方案

智能化
防护

场景化
应用

V2X安全解决方案
持续创新

威胁检测与响应
实时监控

技术支撑与发展方向

威胁情报共享
Auto-ISACs
协同防护

行业标准统一
国际互认
互操作性

前沿安全技术
AI安全 PQC
BAS 持续研发

人才培养
复合型安全
专业人才

生态协作
开放共享
自适应

供应链

安全服务

车联网数据的安全与隐私保护

数据源层

车辆数据

用户数据

环境数据

基础设施数据

高精地图数据

生物特征数据

数据分类分级层

个人信息

重要数据

一般数据

核心策略层

数据最小化
原则

用户授权与
透明度

隐私增强
技术(PETs)

传输存储
安全

跨境流动
合规

差分隐私

联邦学习

同态加密

数据匿名化

端到端加密

访问控制

数据安全治理体系

安全策略制定

风险评估审计

应急响应机制

隐私安全设计

未来展望：新兴威胁与防御之道

车联网安全是一个持续演进的战场。

人工智能驱动的攻击、电动汽车充电生态系统的脆弱性以及日益复杂的第三方集成，正成为新的主要风险源。

行业需要采取超越合规的、更主动和全面的网络安全战略来应对未来挑战。

强化全生命周期安全

将安全“左移”至设计阶段，实施严格的安全编码规范，并推广使用内存安全的编程语言。

加强供应链安全管理

对供应商建立严格的安全评估和准入机制，要求提供软件物料清单（SBOM），推动责任共担。

提升后端与API安全

鉴于后端已成主要目标，必须确保云平台、API接口及OTA服务器的安全性，实施强身份验证和持续监控。

防护新兴领域风险

针对EV充电生态系统和车载AI系统，需进行专门的安全评估和沙箱化管理，推动相关安全标准建立。

采纳主动对抗性测试

积极引入漏洞赏金计划、渗透测试和红队演练，以发现潜在的未知漏洞（零日漏洞）。

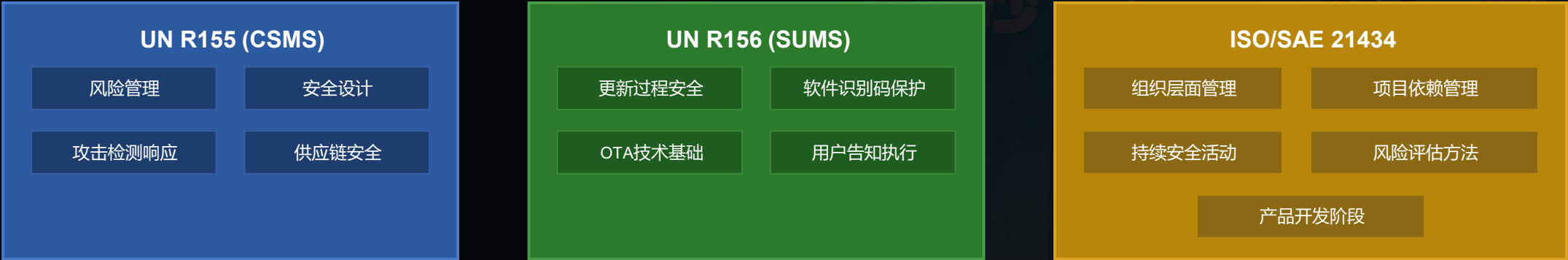
推动信息共享与协作

建立健全的漏洞披露机制和跨组织的行业信息共享平台（如汽车ISAC），提升协同响应能力。

车联网全生命周期安全管理框架

从法规要求到实践落地的系统化安全体系

法规标准层



管理体系层



实施保障层



谢谢

